Coruna Exploit Kit With 23 Exploits Hacked Thousands of iPhones

cybersecuritynews.com/coruna-ios-exploit-kit

Guru Baran March 4, 2026

Home Cyber Security Coruna Exploit Kit With 23 Exploits Hacked Thousands of iPhones

Coruna iOS Exploit Kit

Google's Threat Intelligence Group (GTIG) has uncovered Coruna, a sophisticated iOS exploit kit containing 23 exploits across five full exploit chains that compromised thousands of iPhones running iOS 13.0 through 17.2.1 throughout 2025.

The Coruna exploit kit is an advanced, modular iOS attack framework discovered by GTIG targeting Apple iPhone models from iOS 13.0 (September 2019) to iOS 17.2.1 (December 2023).

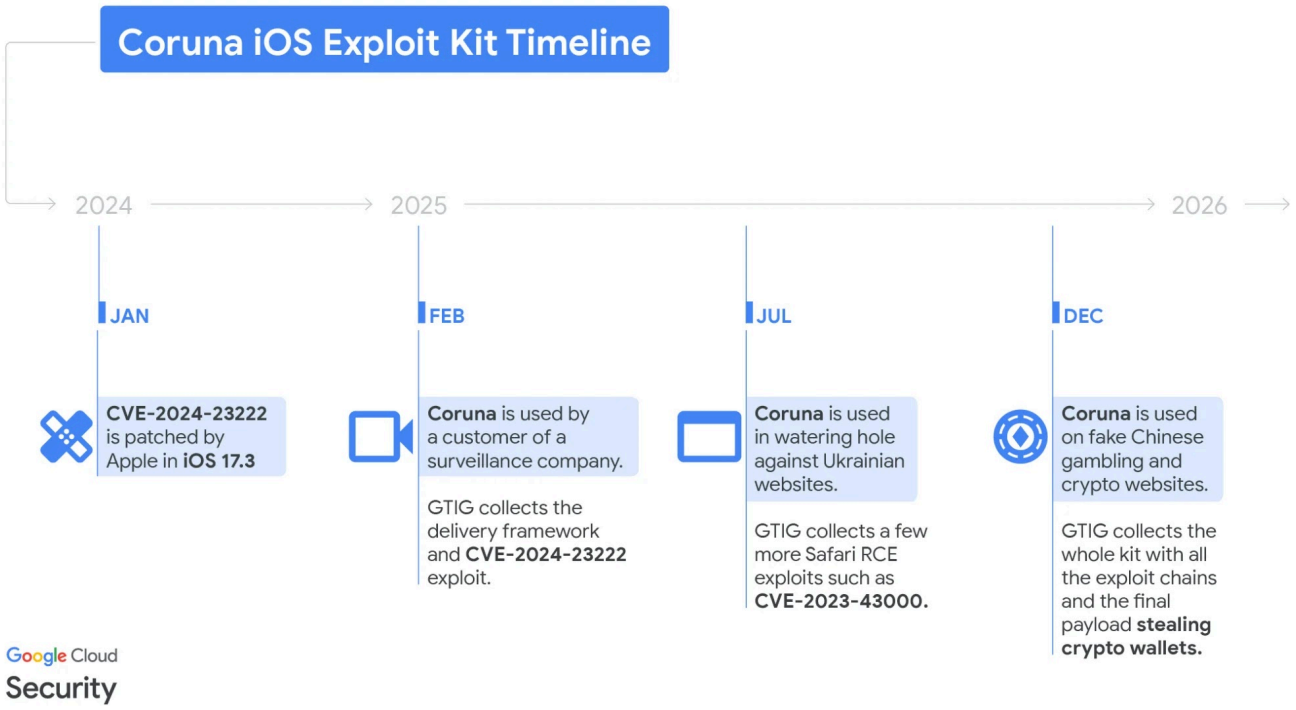
The kit's name was uncovered when one threat actor mistakenly deployed a debug version of the framework, exposing internal code names and the kit's own identity.

Its exploits feature extensive documentation written in native English, with the most advanced components leveraging non-public exploitation techniques and mitigation bypasses, a hallmark of nation-state-grade tooling.

Three-Phase Exploit Timeline

GTIG tracked Coruna moving through three distinct threat actor ecosystems over the course of 2025, a rare window into how elite exploit kits proliferate from commercial surveillance vendors to state-sponsored espionage groups and finally to financially motivated criminals.

- **February 2025 – Commercial Surveillance Customer:** GTIG first captured parts of an iOS exploit chain delivered through a previously unseen JavaScript framework using unique obfuscation techniques. The framework fingerprinted devices to identify the iPhone model and iOS version before loading the appropriate WebKit remote code execution (RCE) exploit followed by a Pointer Authentication Code (PAC) bypass.
- **Summer 2025 – Russian Espionage (UNC6353):** The identical JavaScript framework was found hosted on `cdn.uacounter[.]com`, injected as a hidden iFrame across dozens of compromised Ukrainian websites spanning industrial, retail, and ecommerce sectors. The exploits were selectively delivered based on geolocation to iPhone users. GTIG alerted CERT-UA to clean up all affected websites.
- **Late 2025 – Chinese Financial Fraud (UNC6691):** The complete exploit kit was retrieved from a large network of fake Chinese financial and cryptocurrency websites designed to lure iOS users. One fake WEEX crypto exchange site displayed pop-ups specifically urging users to visit via iPhone.



Coruna Exploit timeline (Source: Google)

The 23 exploits span five full exploit chains that deliver WebKit RCE, PAC bypasses, sandbox escapes, privilege escalation (PE), and PPL (Page Protection Layer) bypasses. Key CVEs include:

Type	Code Name	Targeted iOS Versions	CVE
WebContent R/W	buffout	13 → 15.1.1	CVE-2021-30952
WebContent R/W	jacurutu	15.2 → 15.5	CVE-2022-48503
WebContent R/W	terrorbird	16.2 → 16.5.1	CVE-2023-43000
WebContent R/W	cassowary	16.6 → 17.2.1	CVE-2024-23222
Sandbox Escape	IronLoader	16.0 → 16.3.1	CVE-2023-32409
PE	Photon	14.5 → 15.7.6	CVE-2023-32434
PPL Bypass	Gallium	14.x	CVE-2023-38606
PPL Bypass	Sparrow	17.0 → 17.3	CVE-2024-23225
PPL Bypass	Rocket	17.1 → 17.4	CVE-2024-23296

Two exploits, Photon and Gallium, target vulnerabilities previously used in Operation Triangulation, the Kaspersky-discovered iOS espionage campaign from 2023.

PlasmaLoader: The Financial Theft Payload

At the end of the exploit chain, a stager binary called PlasmaLoader (tracked as PLASMAGRID) injects itself into `powerd`, a root-level iOS daemon, using `com.apple.assistd` as a masquerading identifier.

```
<PlasmaLogger> %s[%d]: CorePayload 管理器初始化成功，尝试启动...
```

The payload targets 18 cryptocurrency wallet applications, including MetaMask, BitKeep, and Phantom, by hooking their functions to exfiltrate sensitive data.

It can also scan Apple Notes for BIP39 seed phrases and keywords like “backup phrase” or “bank account.” All logging strings and code comments are written in Chinese, with evidence of LLM-generated comment structures, strongly pointing to Chinese-speaking developers.

Network communication uses HTTPS with AES encryption, while a custom Domain Generation Algorithm (DGA) seeded with the string “lazarus” generates fallback `.xyz` domains with 15 characters, validated via Google’s public DNS resolver.

GTIG has added all identified domains and websites to Google Safe Browsing. The Coruna exploit kit is not effective against the latest version of iOS. Security teams and users should act on the following:helpnetsecurity+1

- Immediately update all iPhones to the latest iOS version.
- Enable Lockdown Mode if updating is not possible — Coruna actively bails out when Lockdown Mode is detected.
- Avoid private or unverified financial/crypto websites accessed via mobile Safari.
- Monitor for anomalous network requests to `.xyz` domains or HTTP headers `sdkv` and `x-ts` as potential C2 indicators.

Top 10

Essential E-Signature Solutions for Cybersecurity in 2026

Top 10 Best Data Removal Services In 2026

Best VPN Services of 2026: Fast, Secure & Affordable

Top 10 Best Data Security Companies in 2026

Top 15 Best Ethical Hacking Tools – 2026